PENETRATION TESTING REPORT

Task 4 Exploitation and System Security

Controlled Assessment of an Intentionally Vulnerable Metasploitable2 Lab Target

Assessment Information	Details
Program	APEX Planet Internship
Assessment type	Controlled and authorized laboratory penetration test
Primary target	Metasploitable2 intentionally vulnerable training target
Testing workstation	Kali Linux
Evidence set	SS-01 through SS-22, including SS-20A to SS-20C
Report purpose	Academic and internship submission

Confidentiality and authorization statement

All testing described in this report was performed only within a controlled, authorized laboratory environment. Metasploitable2 is deliberately vulnerable and was used solely as a training target. The activities, credentials, hashes and malware-analysis material discussed here must not be interpreted as testing of a production system or third-party asset.

Report Contents

• 1. Executive Summary

• 2. Objective and Scope

• 3. Lab Environment and Methodology

• 4. Findings Summary and Risk Discussion

• 5. Reconnaissance and Scanning

• 6. Exploitation and Post Exploitation

• 7. Credential Security Testing

• 8. Malware Analysis

• 9. System Hardening

• 10. Mitigations and Recommendations

• 11. Limitations

• 12. Conclusion

• Appendix A Evidence Register

1. Executive Summary

This report documents a controlled penetration-testing exercise completed for APEX Planet Task 4, Exploitation and System Security. The assessment used a Kali Linux workstation against Metasploitable2, an intentionally vulnerable laboratory target. The supplied evidence records lab identification, connectivity validation, reconnaissance, TCP and UDP scanning, Metasploit configuration, reverse-shell access, post-exploitation collection, credential-security exercises, malware-analysis activity and host-hardening checks.

The evidence demonstrates that the target exposed a broad service surface suitable for a controlled exploitation exercise. A Metasploit module was configured and a reverse-shell/session result was captured. Follow-on evidence shows system-information collection and password-hash extraction. Separate password-security exercises document SSH testing with Hydra and password-cracking activity with John the Ripper. The evidence also records static and dynamic malware-analysis activity, update verification, firewall configuration and removal of an unused Telnet service.

Because Metasploitable2 is designed to be insecure, the observed conditions should be understood as training findings rather than an enterprise risk assessment. The principal lesson is that exposed legacy services, weak credential controls, unpatched software and excessive service availability can combine to permit rapid compromise. Recommendations are clearly identified as corrective guidance and are not presented as completed changes unless visible in the supplied evidence.

2. Objective and Scope

2.1 Objectives

• Establish the controlled Kali Linux and Metasploitable2 lab context and confirm connectivity.

• Perform reconnaissance and service enumeration sufficient to identify an attack surface.

• Configure and demonstrate Metasploit exploitation and reverse-shell/session access.

• Perform limited post-exploitation collection, including system information and password-hash extraction.

• Demonstrate credential-security testing with Hydra and John the Ripper inside the lab.

• Perform static and dynamic malware-analysis activities documented in the evidence set.

• Demonstrate selected hardening activities: update checks, firewall configuration and removal of unused Telnet access.

• Provide a traceable evidence register preserving the SS-01 through SS-22 labels.

2.2 Scope and Boundaries

In scope were the Kali Linux test workstation, the Metasploitable2 laboratory target and the evidence-backed exercises shown in SS-01 through SS-22. The assessment was controlled and authorized. It did not test public IP addresses, production systems, third-party accounts or externally hosted services. This report does not claim a comprehensive vulnerability assessment, persistence testing, denial-of-service testing, social engineering, lateral movement or remediation validation beyond the explicit hardening screenshots.

3. Lab Environment and Methodology

3.1 Environment

Component	Role	Evidence basis
Kali Linux	Test workstation / attacker system	SS-01 identifies the Kali lab system.
Metasploitable2	Intentionally vulnerable training target	SS-02 identifies the target; later evidence records target activity.
Controlled lab network	Isolated communication path for authorized testing	SS-03 confirms a connectivity check; SS-04 begins host discovery.
Metasploit	Exploit-framework configuration and session establishment	SS-12 and SS-13.
Hydra and John the Ripper	Credential-security testing utilities	SS-16 and SS-17.

3.2 Methodology

The testing flow followed a disciplined progression: identify the lab systems; verify reachability; discover and enumerate the target; configure an evidence-backed exploitation path; collect only the post-exploitation information captured in the evidence; conduct credential and malware-analysis exercises; and document selected system-hardening checks. Each stage is mapped to a screenshot label in Appendix A. A screenshot proves only what is visible in that screenshot, so this report avoids asserting unrecorded commands, versions, credentials or outcomes.

3.3 Evidence Handling

The supplied evidence PDF is the factual source. SS-01 through SS-22 are retained verbatim as identifiers; SS-20 is represented by the three supplied source labels SS-20A, SS-20B and SS-20C. The previous Task 3 report was used only as an editorial and structural reference. It was not used as a factual source, and this Task 4 report does not describe DVWA or web-application findings.

4. Findings Summary and Risk Discussion

The ratings below are assessor judgments for the intentionally vulnerable lab, not automated scores or results printed by the screenshots. They reflect the demonstrated pathway and the likely impact of equivalent conditions on a real system.

ID	Observed condition	Evidence	Lab risk	Why it matters
F-01	Exposed network services and identifiable service surface	SS-04 to SS-11	High	A large and discoverable service surface increases potential attack paths.
F-02	Metasploit exploitation and reverse-shell/session evidence	SS-12 to SS-13	Critical	The exercise demonstrates a compromise path and interactive access in the lab.
F-03	System information and password hashes accessible after compromise	SS-14 to SS-15	Critical	Host details and credential material can enable further unauthorized access.

ID	Observed condition	Evidence	Lab risk	Why it matters
F-04	SSH password-security testing and cracking activity	SS-16 to SS-17	High	Weak or guessable passwords can turn exposed remote access into compromise.
F-05	Legacy Telnet service required removal; hardening checks documented	SS-20A to SS-22	High	Legacy plaintext remote services and missing controls increase exposure.

In a real environment, F-02 and F-03 would normally take immediate priority because successful interactive access and credential material can provide a direct route to data loss, further compromise and loss of system control. The intentionally insecure design of Metasploitable2 magnifies these conditions; the report therefore does not extrapolate a measured enterprise likelihood or business impact.

5. Reconnaissance and Scanning

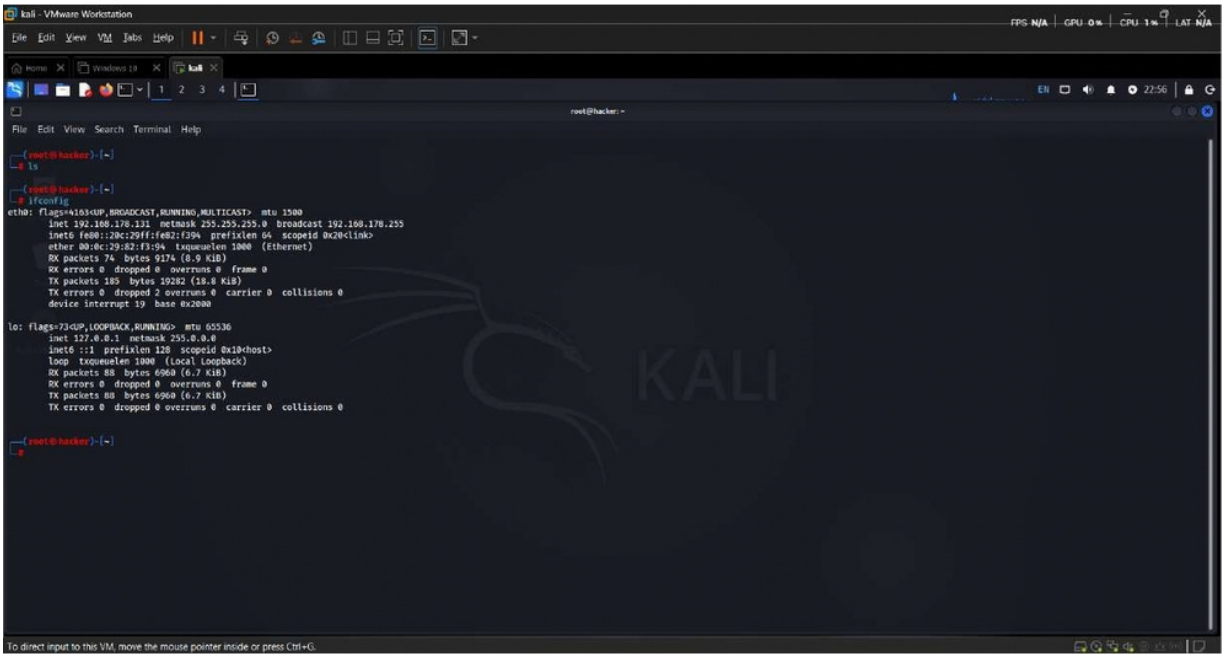
5.1 Baseline Identification and Connectivity

SS-01 and SS-02 establish the two lab endpoints. SS-03 records the connectivity test before enumeration began. This sequence supports the assessment boundary: activity was directed at the controlled lab target after reachability was checked, rather than at an unspecified external host.

5.2 Discovery and Enumeration

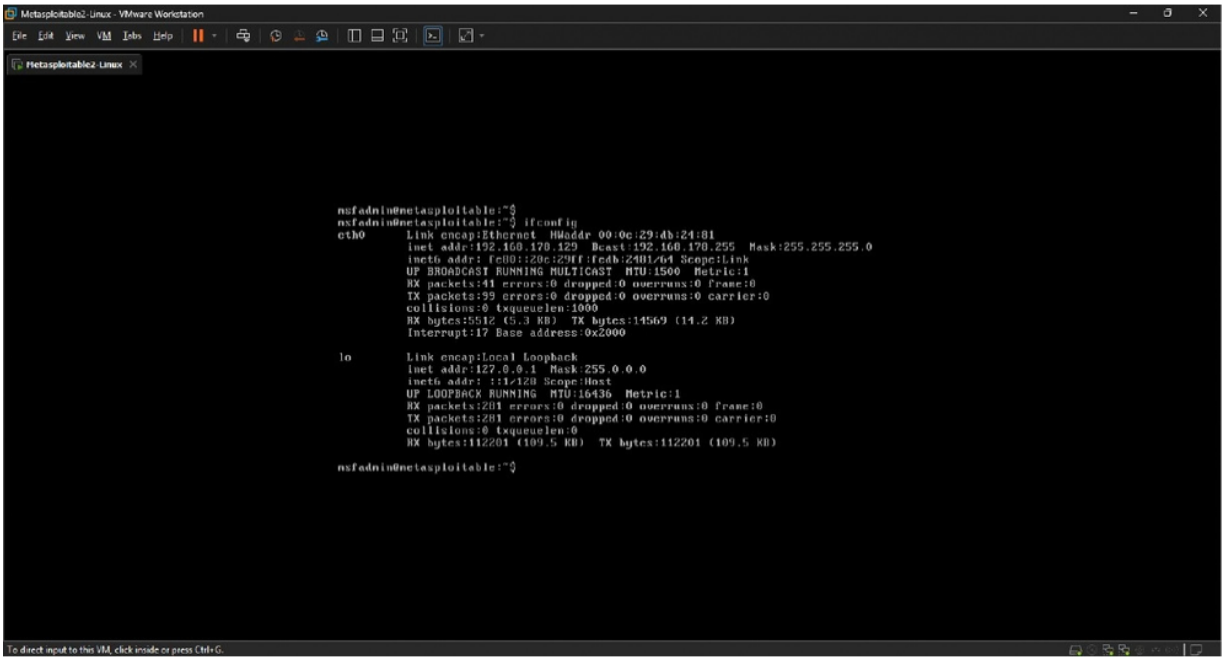
The evidence set documents network host discovery (SS-04), target DNS reconnaissance (SS-05), basic target reconnaissance (SS-06), full TCP port scanning (SS-07), service-version detection (SS-08), operating-system detection (SS-09), UDP port scanning (SS-10), and consolidated service enumeration (SS-11). Together, these stages show a layered approach rather than reliance on one scan type.

Observed interpretation: the enumeration sequence provided the information needed to select an exploitation approach. The report intentionally does not reproduce unverified port numbers, service versions, hostnames or operating-system claims beyond what a reader can inspect in the embedded screenshots.



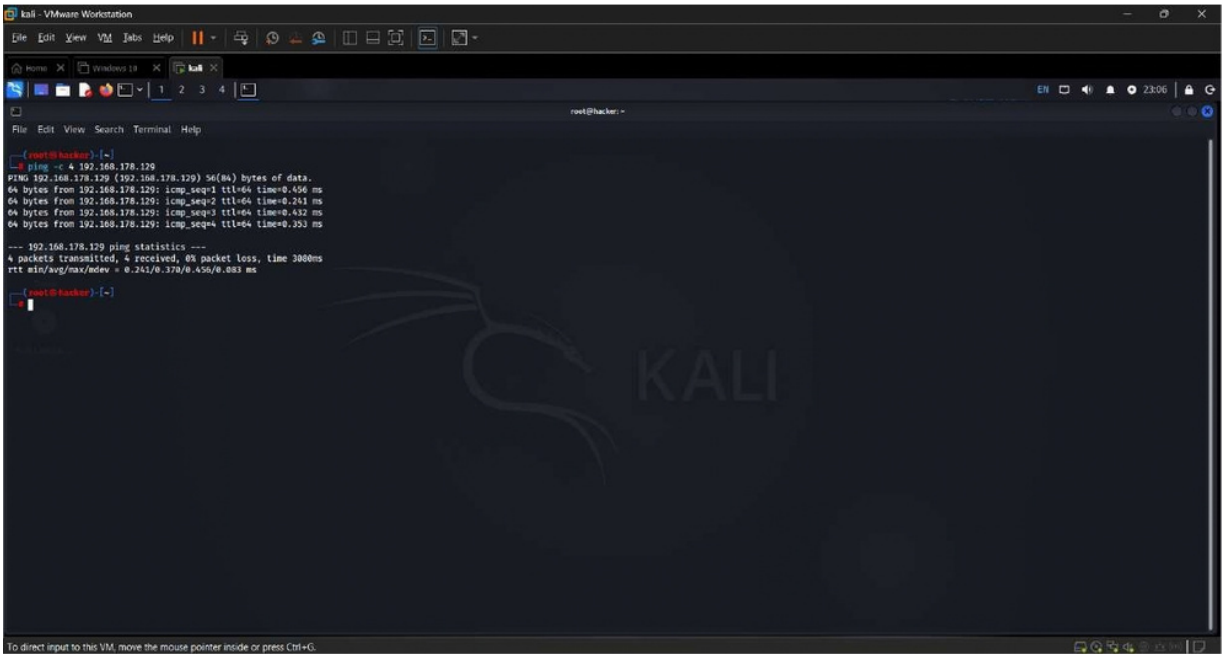
SS-01-kali-ip

Figure 1. SS-01-kali-ip. Kali Linux test workstation address displayed.



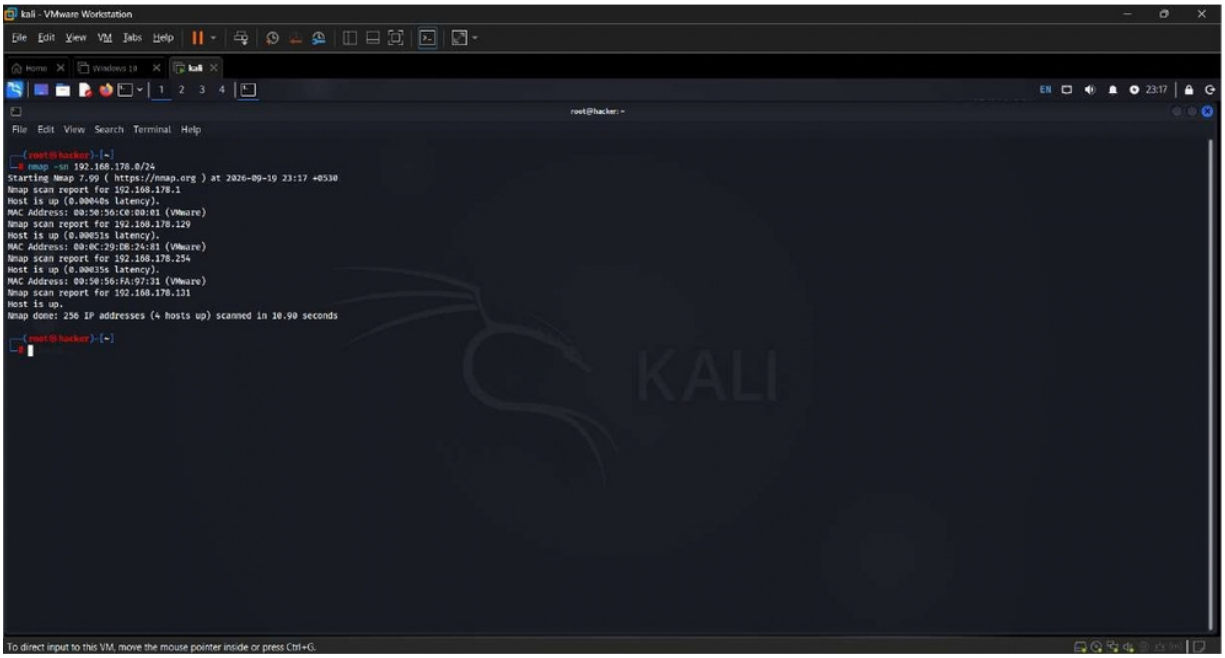
SS-02-metasploitable-ip

Figure 2. SS-02-metasploitable-ip. Metasploitable2 target address displayed.



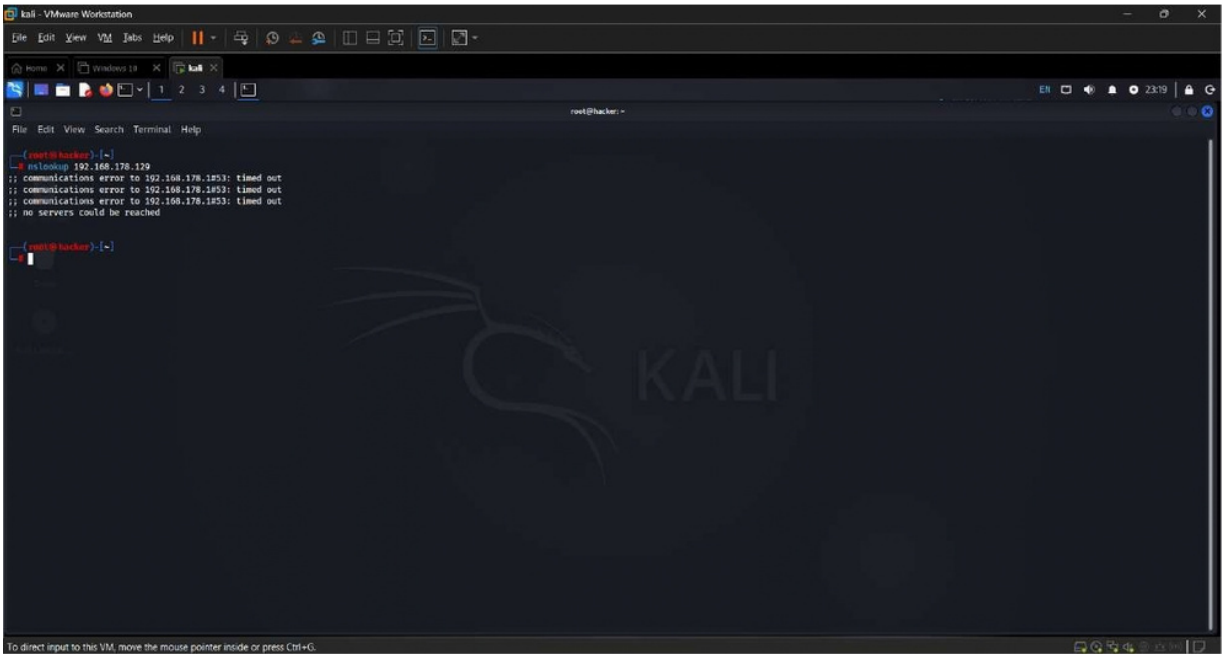
SS-03-connectivity-test

Figure 3. SS-03-connectivity-test. Reachability test between the controlled lab systems.



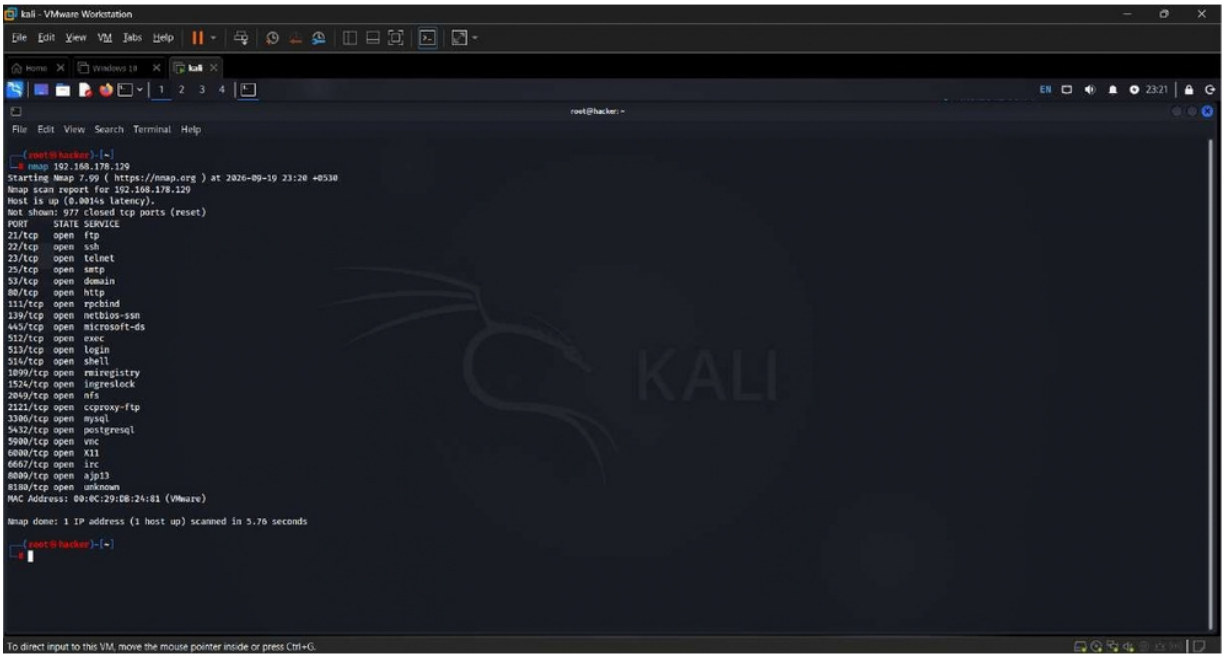
SS-04-network-host-discovery

Figure 4. SS-04-network-host-discovery. Network host discovery output.



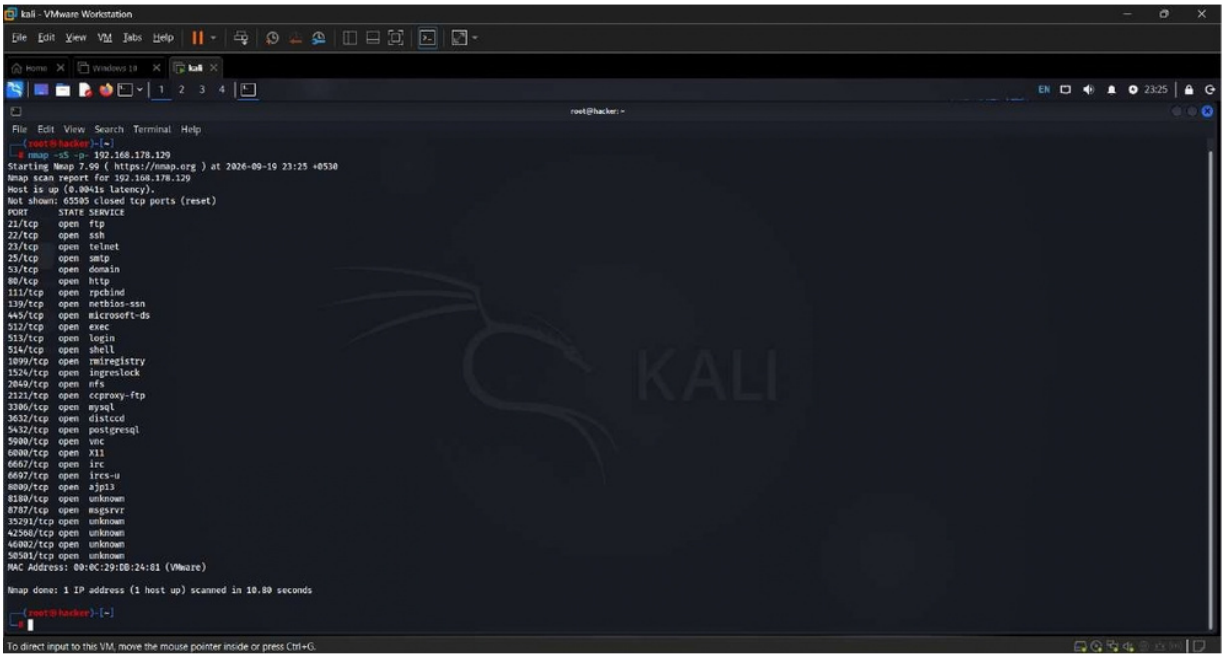
SS-05-target-dns-recon

Figure 5. SS-05-target-dns-recon. Target DNS reconnaissance output.



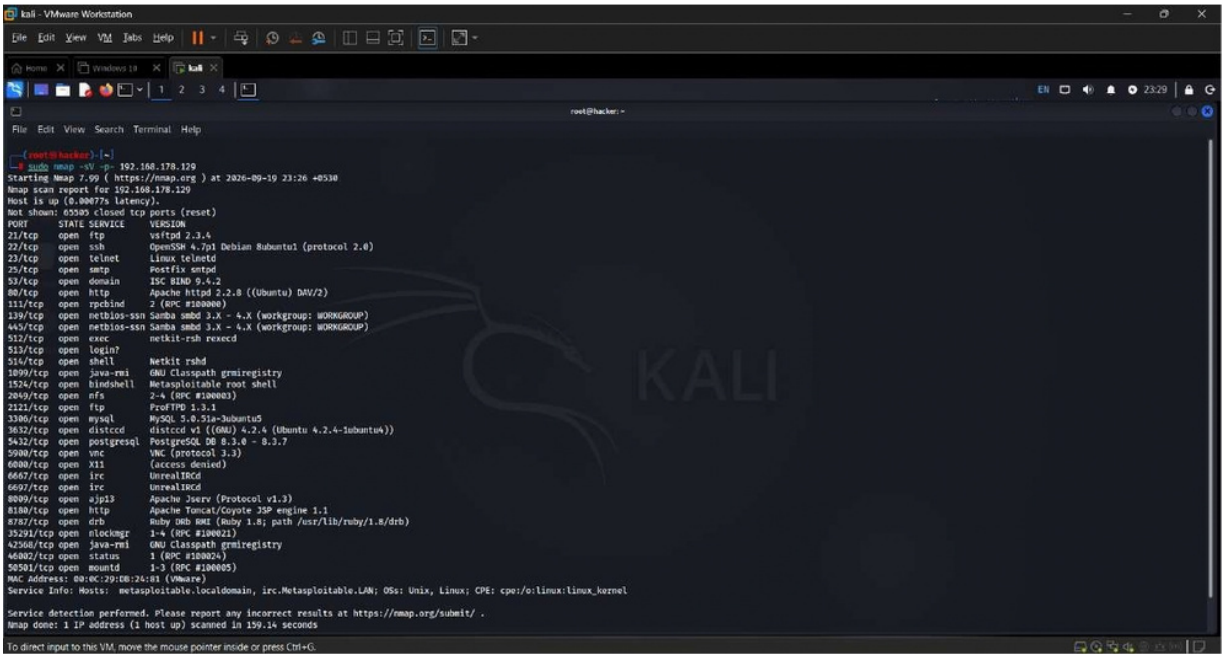
SS-06-basic-target-recon

Figure 6. SS-06-basic-target-recon. Basic target reconnaissance output.



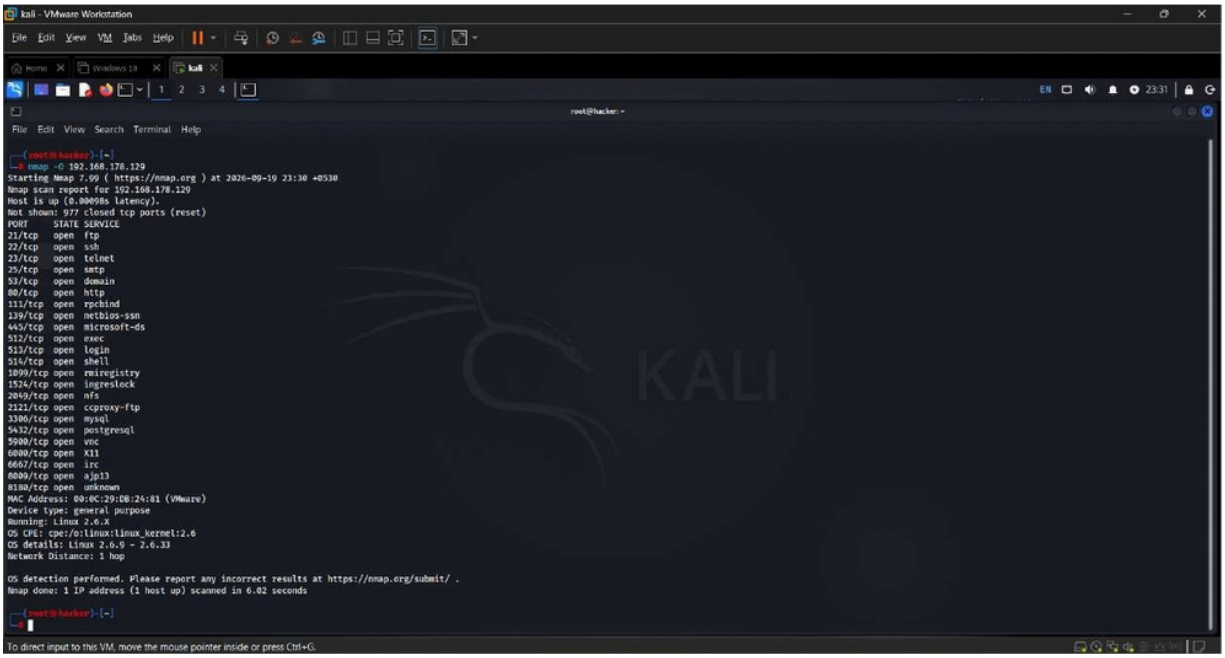
SS-07-full-tcp-port-scan

Figure 7. SS-07-full-tcp-port-scan. Full TCP port scan output.



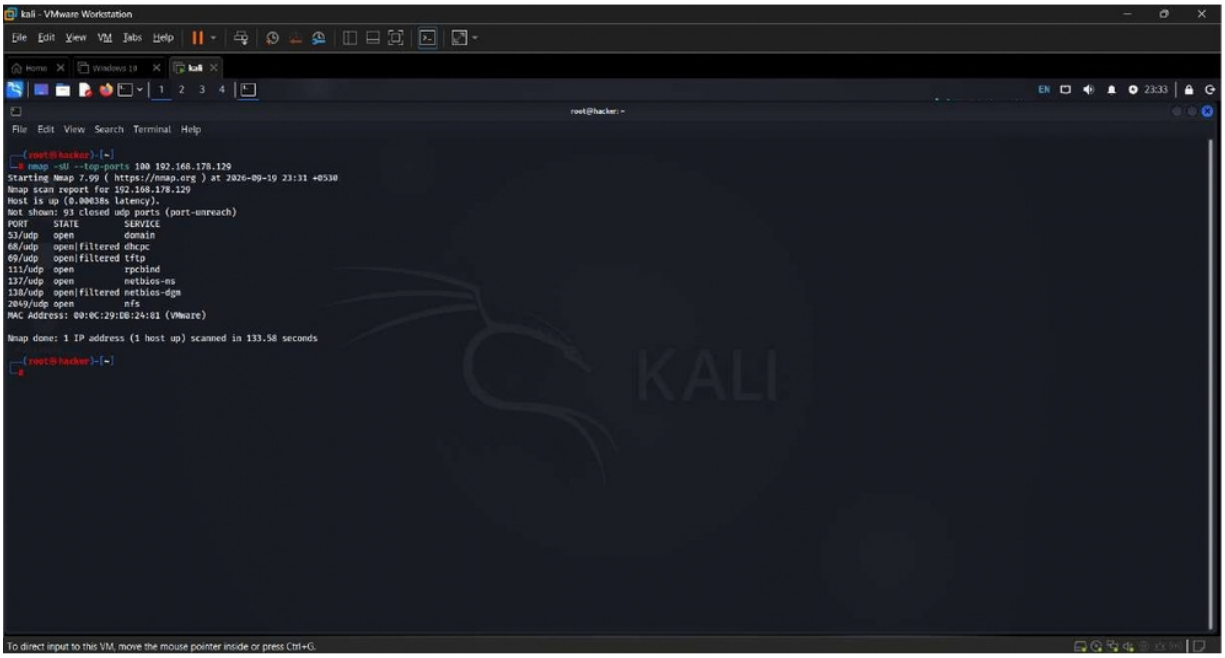
SS-08-service-version-detection

Figure 8. SS-08-service-version-detection. Service and version detection output.



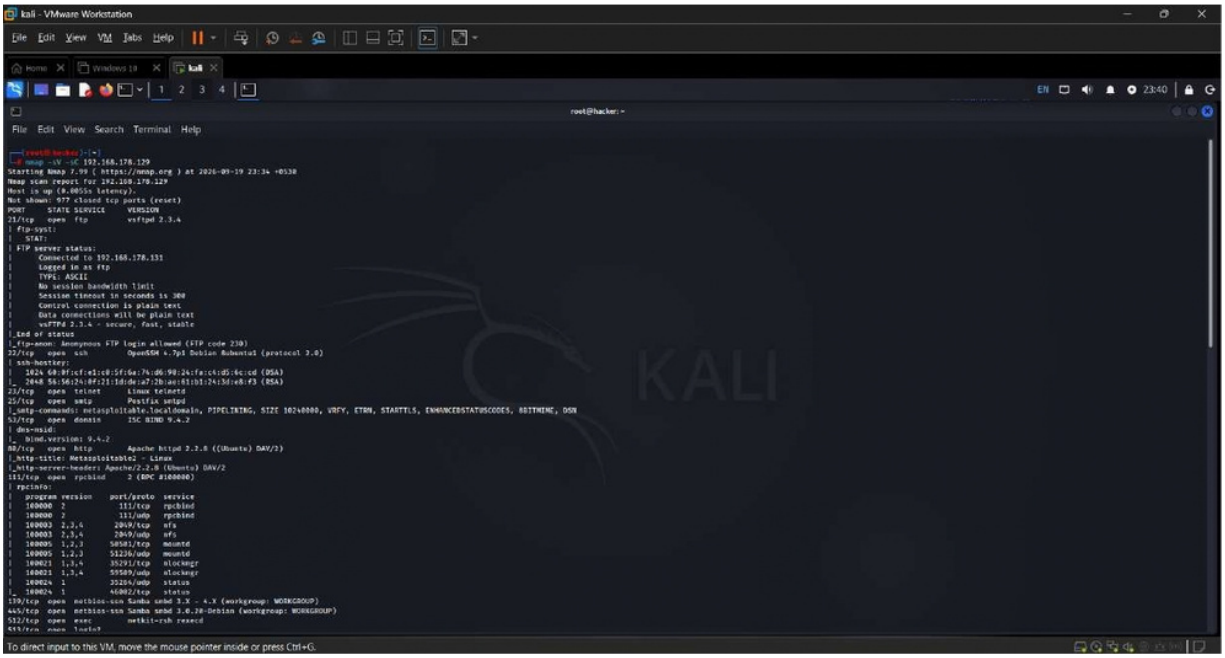
SS-09-os-detection

Figure 9. SS-09-os-detection. Operating-system detection output.



SS-10-udp-port-scan

Figure 10. SS-10-udp-port-scan. UDP port scan output.



SS-11-consolidated-service-enumeration

Figure 11. SS-11-consolidated-service-enumeration. Consolidated service enumeration output.

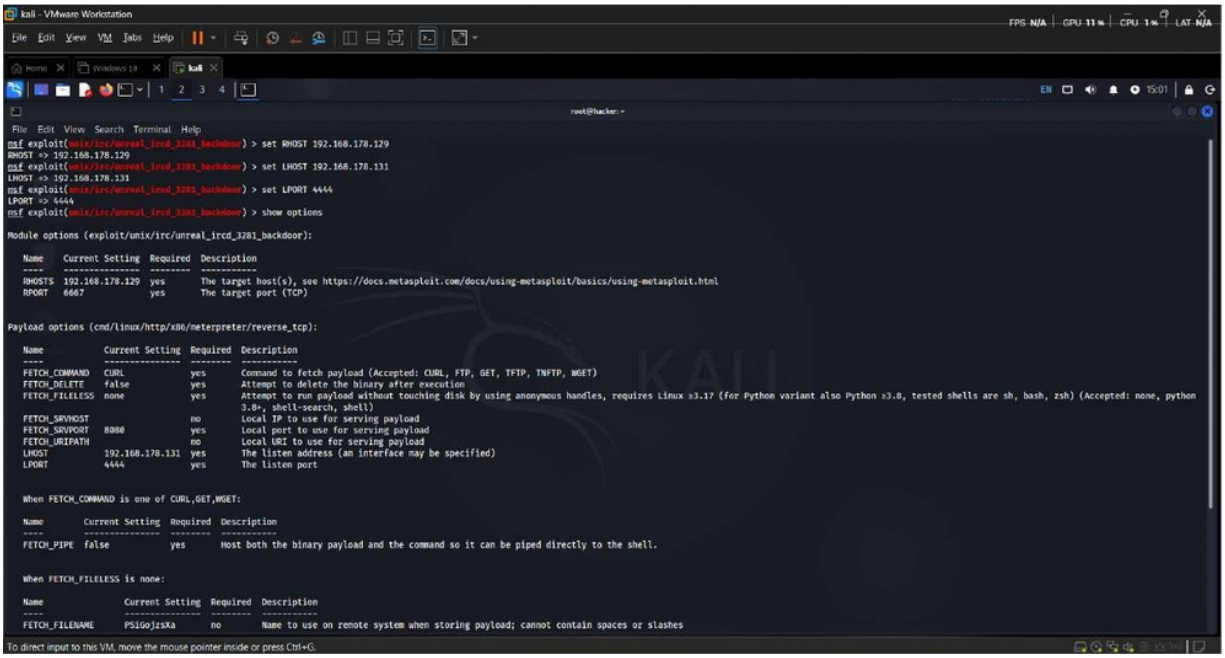
6. Exploitation and Post Exploitation

6.1 Metasploit Configuration and Reverse Shell

SS-12 records a Metasploit exploit-configuration stage. SS-13 records the resulting reverse-shell/session evidence. In the controlled Metasploitable2 environment, this is sufficient to demonstrate that the selected framework workflow progressed from configuration to post-compromise interaction. It should not be read as a claim that the same module is applicable to any other system.

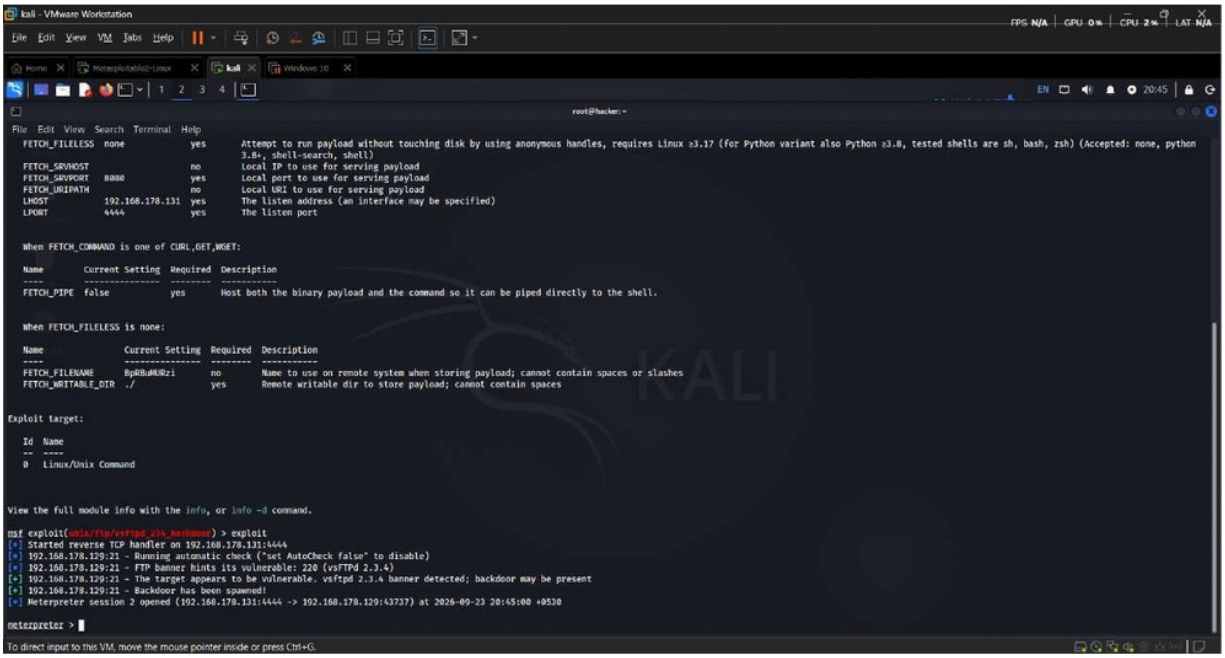
6.2 System Information and Password Hash Extraction

After the session was obtained, SS-14 documents collection of system information and SS-15 documents password-hash extraction. These actions illustrate why a successful initial compromise can be more serious than a single service failure: local host details and credential material can support privilege escalation, credential reuse or further targeting. Any sensitive values visible in the evidence are laboratory values and are not reproduced as usable credential data in the narrative.



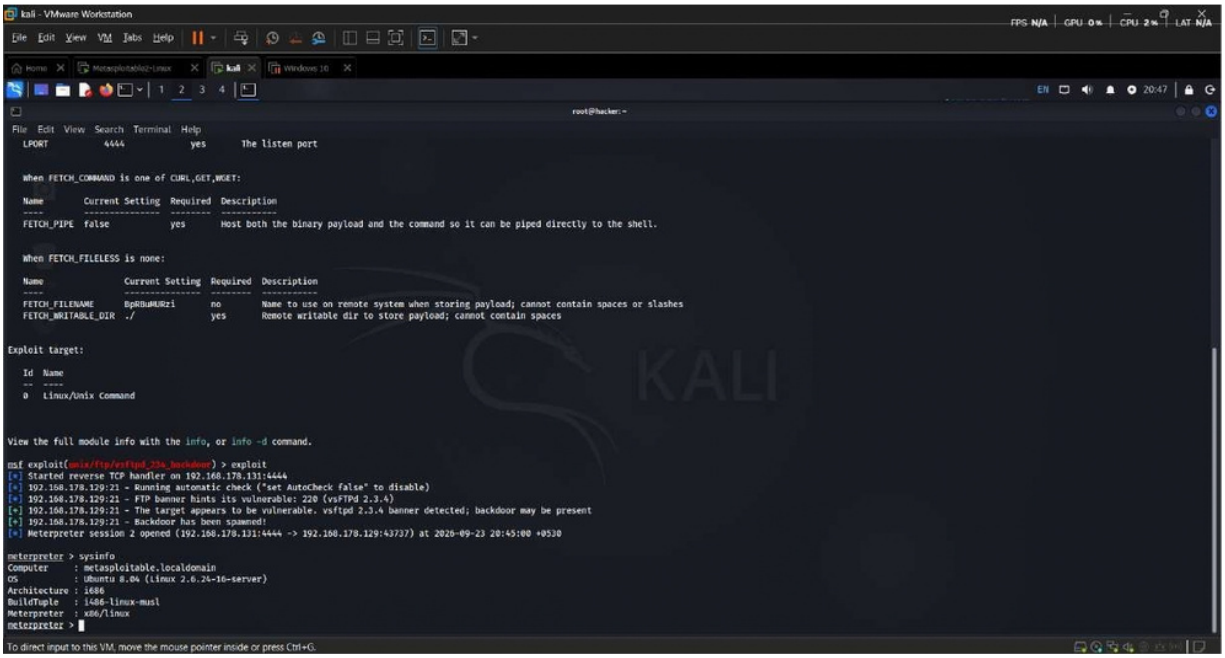
SS-12-metasploit-exploit-configuration

Figure 12. SS-12-metasploit-exploit-configuration. Metasploit module configuration before execution.



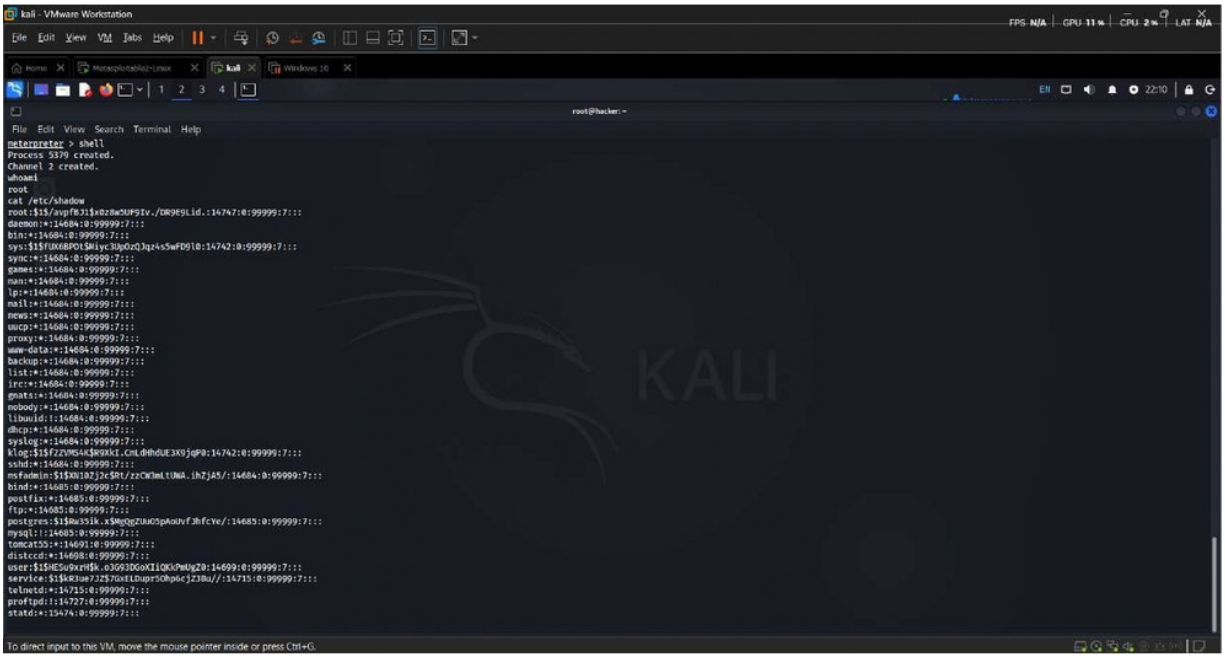
SS-13-reverse-shell

Figure 13. SS-13-reverse-shell. Reverse shell/session evidence in the lab.



SS-14-sysinfo

Figure 14. SS-14-sysinfo. System information collected from the obtained session.



SS-15-hashdump

Figure 15. SS-15-hashdump. Password hash extraction output.

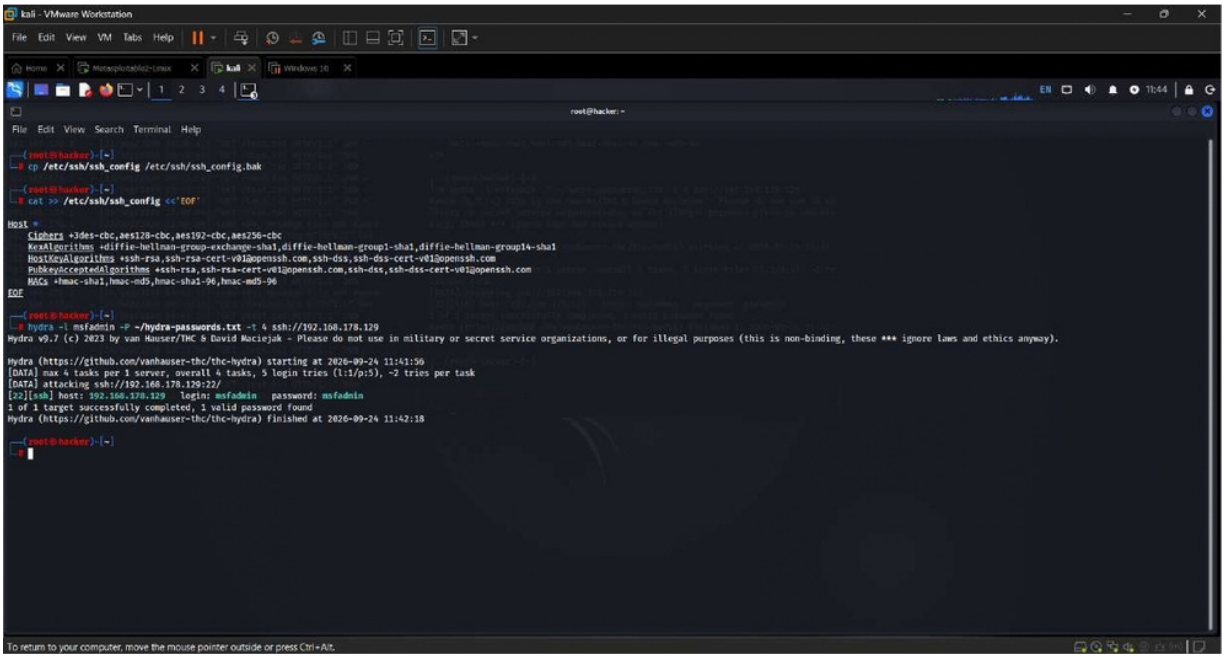
7. Credential Security Testing

7.1 Hydra SSH Testing

SS-16 documents a Hydra SSH exercise. In the authorized lab, the purpose is to show the exposure created by weak or reusable SSH passwords. The screenshot is treated as the record of the tool output; this report does not infer the size of the password list, account population, rate limits or outcomes beyond what appears in the source figure.

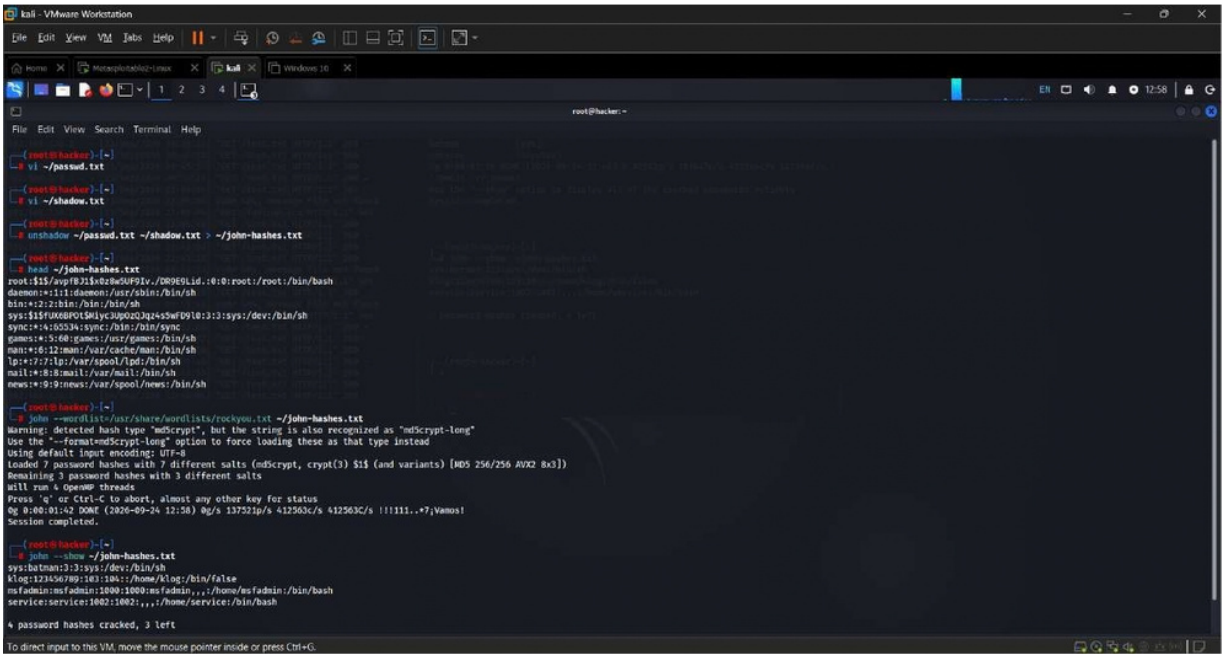
7.2 John the Ripper Password Cracking

SS-17 documents John the Ripper activity. The source label is retained exactly as SS-17-Jhon for evidence traceability, while the narrative uses the correct tool name. Together with SS-15, this exercise reinforces that password hashes should be protected as sensitive assets and that weak passwords can remain vulnerable even when stored as hashes.



SS-16-hydra

Figure 16. SS-16-hydra. Hydra SSH authentication testing output.



SS-17-Jhon

Figure 17. SS-17-Jhon. John the Ripper cracking output; source label retains Jhon.

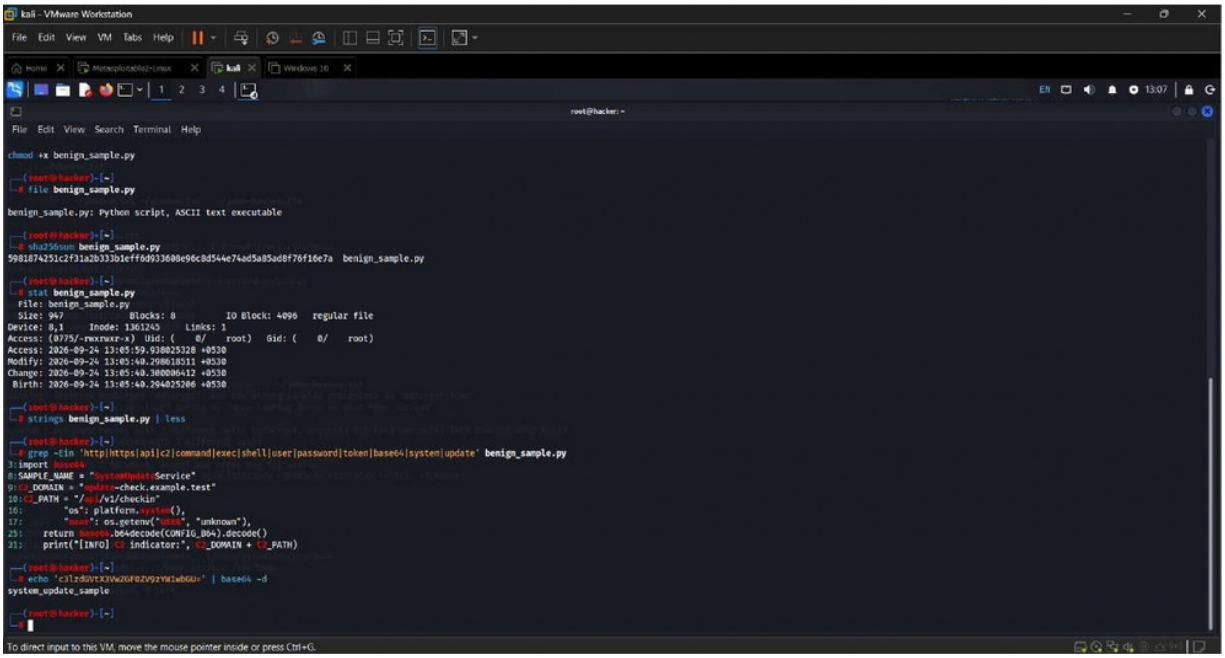
8. Malware Analysis

8.1 Static Analysis

SS-18 records static malware-analysis activity. Static analysis examines an item without executing it and can identify properties such as file metadata, strings, hashes, headers or other indicators depending on the utility used. The report does not claim a particular sample family, malicious capability or definitive verdict because those details are not independently established outside the visible evidence.

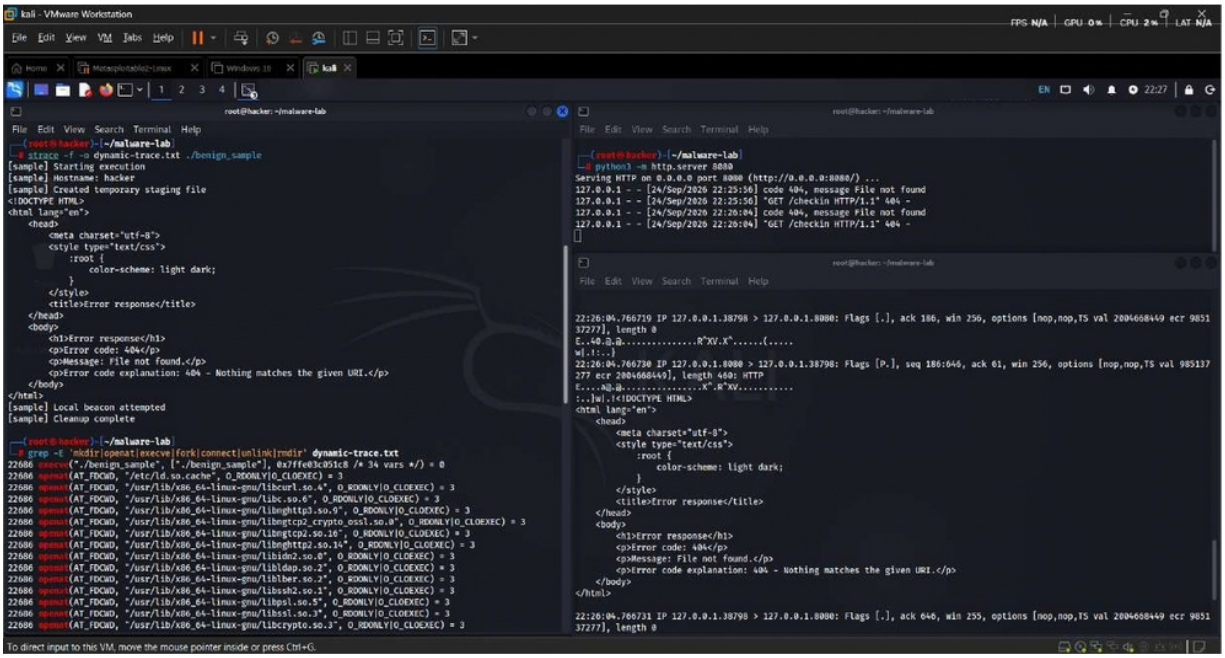
8.2 Dynamic Analysis

SS-19 records dynamic malware-analysis activity. Dynamic analysis observes behavior in a controlled environment and can reveal process, file-system, network or system effects. It should be performed only in an isolated analysis environment. The evidence supports that dynamic-analysis commands/output were captured; it does not justify claims about persistence, command-and-control, data exfiltration or a named malware family unless visible in the figure.



SS-18-static-analysis

Figure 18. SS-18-static-analysis. Static malware analysis commands/output.



SS-19-dynamic-analysis

Figure 19. SS-19-dynamic-analysis. Dynamic malware analysis commands/output.

9. System Hardening

9.1 Update and Patch Verification

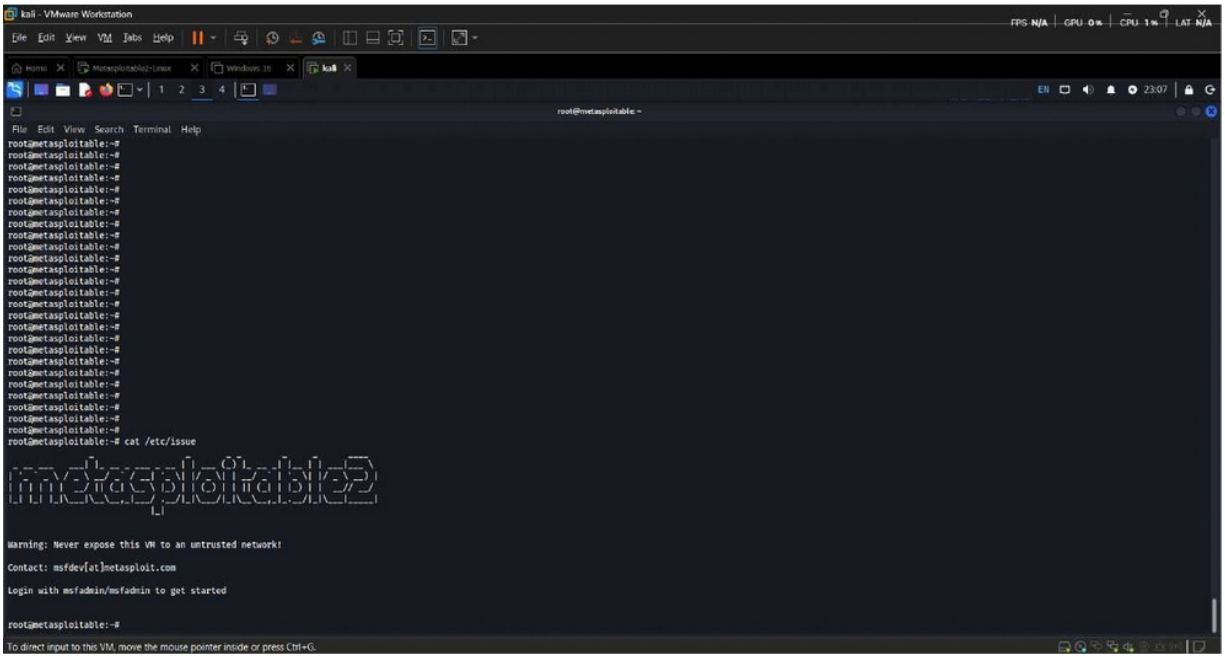
SS-20A captures the operating-system state, SS-20B captures an update check, and SS-20C captures a patch simulation. These three source pages form the SS-20 hardening sequence. They demonstrate review and simulation activity; a simulation should not be confused with proof that every available patch was applied successfully. Production remediation should include a maintenance window, backups, patch deployment, reboot/service-impact planning and verification.

9.2 Firewall Configuration

SS-21 captures firewall configuration. Host-based firewall controls reduce unnecessary exposure when they are backed by an explicit allowlist of required services and tested from approved management paths. The screenshot supports that firewall configuration was addressed in the lab; the report does not claim a complete production policy or network-segmentation design.

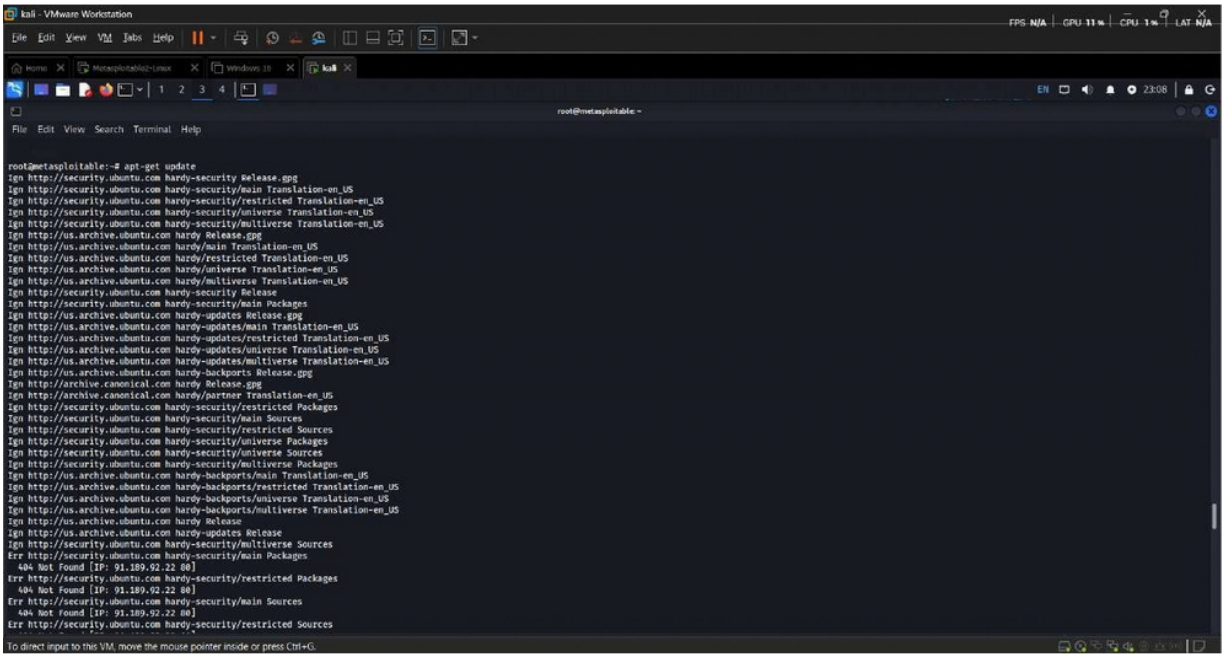
9.3 Disabling Unused Telnet

SS-22 captures the unused-service hardening activity. The evidence shows the intended identify-disable-verify approach for Telnet: the service is removed or disabled and the resulting listener state is checked while SSH remains available. This is an important improvement because Telnet transmits credentials in plaintext and should not be used for remote administration. The screenshot is the evidence for the completed lab action; the recommended enterprise control is to remove the service package or configuration and monitor for re-enablement.



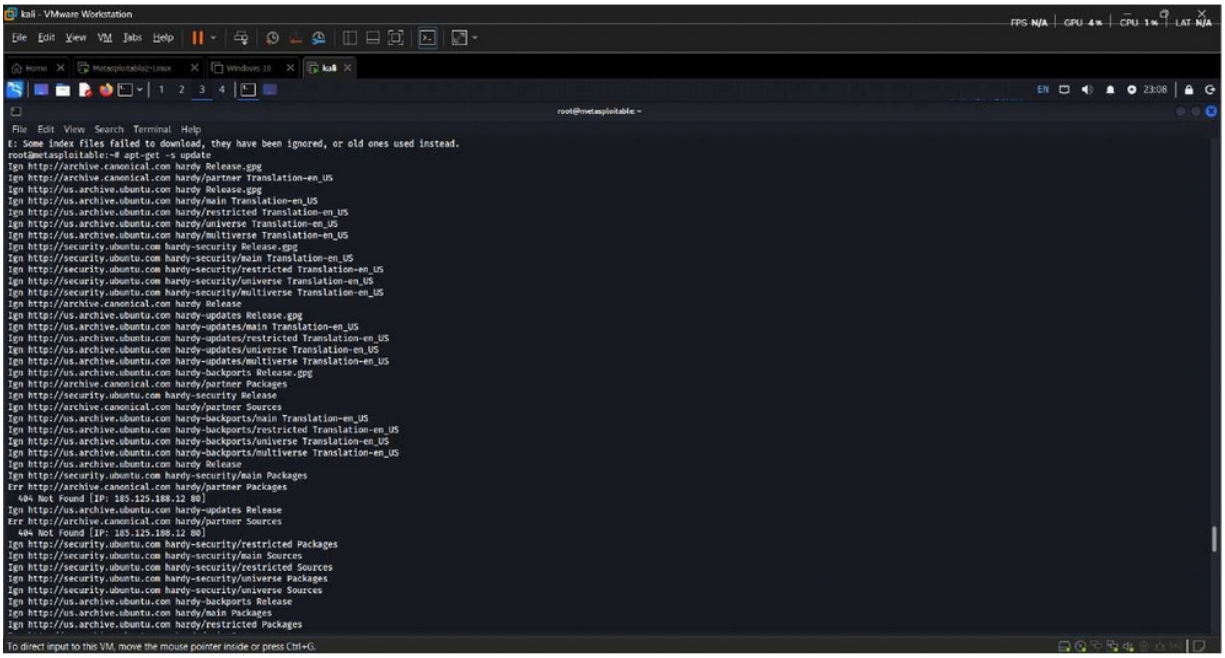
SS-20A-os-state

Figure 20. SS-20A-os-state. Operating-system state captured before update verification.



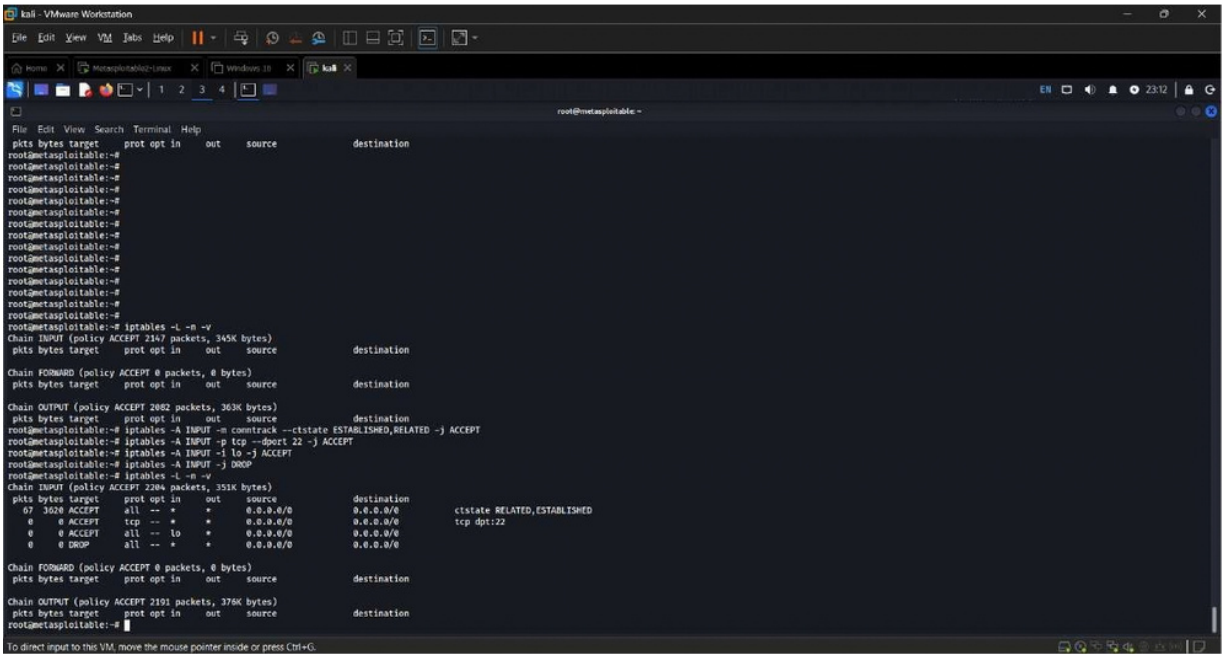
SS-20B-update-check

Figure 21. SS-20B-update-check. Security update check output.



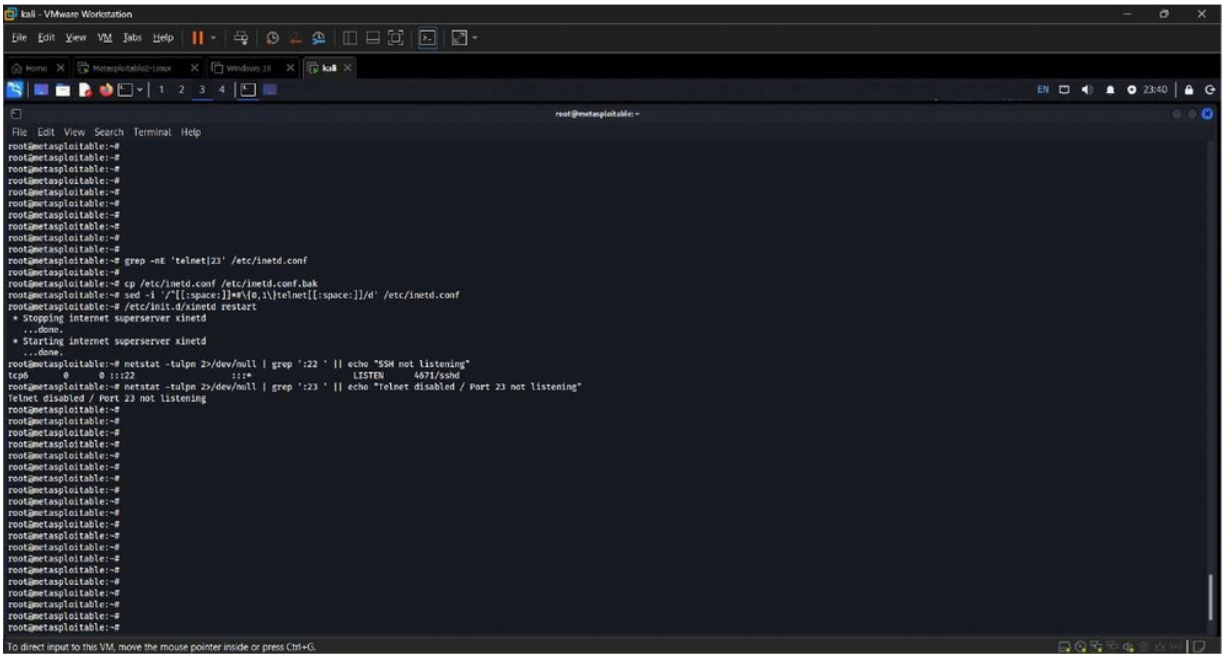
SS-20C-patch-simulation

Figure 22. SS-20C-patch-simulation. Patch simulation output.



SS-21-firewall

Figure 23. SS-21-firewall. Firewall configuration output.



SS-22-disable-unused-service

Figure 24. SS-22-disable-unused-service. Telnet service disablement and verification output.

10. Mitigations and Recommendations

Priority	Recommendation	Rationale / validation
Immediate	Remove or isolate vulnerable legacy services; explicitly retire Telnet.	SS-22 demonstrates the lab removal. Use SSH with modern configuration for supported administration.
Immediate	Patch or replace unsupported systems and applications.	Use a change-controlled process. SS-20 records checks/simulation, not universal patch completion.
Immediate	Rotate exposed laboratory credentials and invalidate hashes if any leave the approved environment.	SS-15 to SS-17 demonstrate the sensitivity of password material and weak-password exposure.
High	Use a default-deny host firewall policy with only business-required ports allowed.	SS-21 records firewall work; validate access from authorized and unauthorized network positions.
High	Enforce strong passwords, MFA where applicable, lockout/rate controls and secure SSH configuration.	Mitigates online guessing and reduces the impact of password reuse.
High	Segment administrative services and monitor authentication, service and firewall events.	Reduces reachability and improves detection of enumeration and post-compromise behavior.
Ongoing	Maintain asset inventory, vulnerability management and recurring security testing.	The SS-04 to SS-11 sequence shows how quickly a visible attack surface can be profiled.
Ongoing	Use isolated tooling and procedures for malware analysis.	Prevents a potentially unsafe sample from affecting production environments.

11. Limitations

• This is a controlled lab assessment against Metasploitable2, not a production penetration test or compliance audit.

• The factual record consists of supplied screenshots. Live logs, packet captures, full terminal histories and independent retesting data were not supplied.

• Risk ratings are assessor judgments for the laboratory scenario and are not formal CVSS scores or enterprise risk scores.

• The report does not infer unshown service versions, account credentials, malware identity, exploit reliability, persistence or patch completion.

• SS-20A to SS-20C are distinct source pages but are grouped as the SS-20 update-hardening sequence for reporting clarity.

• The embedded screenshots may contain laboratory technical details; they are included to preserve evidence traceability and should not be reused as operational instructions against systems without authorization.

12. Conclusion

The controlled Task 4 assessment demonstrates the complete security-testing progression requested for the internship exercise: lab identification, connectivity, reconnaissance, service enumeration, Metasploit exploitation, reverse-shell access, post-exploitation collection, credential-security testing, malware-analysis activity and selected hardening measures. The evidence shows why intentionally vulnerable and poorly hardened systems are at elevated risk: a discoverable service surface can lead to compromise, and a successful session can expose host information and credential material.

The report deliberately separates observed evidence from guidance. Observed results are mapped directly to SS-01 through SS-22. Recommended actions focus on removing obsolete services, keeping systems supported and patched, restricting exposure with a firewall, strengthening authentication, segmenting access and continuously monitoring and reassessing the environment. These controls would materially reduce the attack paths demonstrated in the laboratory exercise.

Appendix A Evidence Register

This register preserves the source labels used in the evidence PDF. The Figure column refers to the figures embedded within their relevant report sections.

Figure	Evidence label	Area	Evidence purpose
Figure 1	SS-01-kali-ip	Lab identification	Kali Linux test workstation address displayed.
Figure 2	SS-02-metasploitable-ip	Lab identification	Metasploitable2 target address displayed.
Figure 3	SS-03-connectivity-test	Connectivity	Reachability test between the controlled lab systems.
Figure 4	SS-04-network-host-discovery	Reconnaissance	Network host discovery output.
Figure 5	SS-05-target-dns-recon	Reconnaissance	Target DNS reconnaissance output.
Figure 6	SS-06-basic-target-recon	Reconnaissance	Basic target reconnaissance output.
Figure 7	SS-07-full-tcp-port-scan	Scanning	Full TCP port scan output.
Figure 8	SS-08-service-version-detection	Scanning	Service and version detection output.
Figure 9	SS-09-os-detection	Scanning	Operating-system detection output.
Figure 10	SS-10-udp-port-scan	Scanning	UDP port scan output.
Figure 11	SS-11-consolidated-service-enumeration	Scanning	Consolidated service enumeration output.
Figure 12	SS-12-metasploit-exploit-configuration	Exploitation	Metasploit module configuration before execution.
Figure 13	SS-13-reverse-shell	Exploitation	Reverse shell/session evidence in the lab.
Figure 14	SS-14-sysinfo	Post-exploitation	System information collected from the obtained session.
Figure 15	SS-15-hashdump	Post-exploitation	Password hash extraction output.
Figure 16	SS-16-hydra	Password attack	Hydra SSH authentication testing output.
Figure 17	SS-17-Jhon	Password attack	John the Ripper cracking output; source label retains Jhon.
Figure 18	SS-18-static-analysis	Malware analysis	Static malware analysis commands/output.
Figure 19	SS-19-dynamic-analysis	Malware analysis	Dynamic malware analysis commands/output.
Figure 20	SS-20A-os-state	Hardening	Operating-system state captured before update verification.
Figure 21	SS-20B-update-check	Hardening	Security update check output.
Figure 22	SS-20C-patch-simulation	Hardening	Patch simulation output.
Figure 23	SS-21-firewall	Hardening	Firewall configuration output.
Figure 24	SS-22-disable-unused-service	Hardening	Telnet service disablement and verification output.